

Самостійна робота №12: Веб-безпека: OWASP Top 10

Тема: Веб-безпека: OWASP Top 10

Мета: Вивчити основні вразливості веб-застосунків за класифікацією OWASP Top 10, зрозуміти механізми захисту: CSP, HTTPS, безпечне зберігання даних.

Кількість годин: 4

Теоретичний матеріал

OWASP Top 10 - огляд

OWASP (Open Worldwide Application Security Project) - міжнародна організація, що досліджує безпеку веб-застосунків. OWASP Top 10 - перелік найкритичніших вразливостей:

1. **Broken Access Control** - обхід контролю доступу. Користувач отримує доступ до чужих ресурсів (IDOR - Insecure Direct Object Reference, горизонтальна/вертикальна ескалація привілеїв).
2. **Cryptographic Failures** - неправильне використання криптографії: зберігання паролів у відкритому вигляді, слабкі алгоритми хешування, відсутність HTTPS.
3. **Injection** - впровадження коду через вхідні дані: SQL Injection, NoSQL Injection, Command Injection. Захист: параметризовані запити, ORM, валідація вхідних даних.
4. **Insecure Design** - архітектурні вразливості на етапі проектування. Захист: threat modeling, secure design patterns.
5. **Security Misconfiguration** - неправильна конфігурація: стандартні паролі, відкриті порти, зайві сервіси, verbose error messages у продакшні.
6. **Vulnerable and Outdated Components** - використання бібліотек з відомими вразливостями. Інструменти: `npm audit`, Snyk, Dependabot.
7. **Identification and Authentication Failures** - слабка аутентифікація: відсутність rate limiting, слабкі паролі, неправильна обробка сесій.

8. **Software and Data Integrity Failures** - порушення цілісності: незахищені CI/CD pipeline, відсутність перевірки підпису пакетів.
9. **Security Logging and Monitoring Failures** - відсутність логування безпекових подій та моніторингу.
10. **Server-Side Request Forgery (SSRF)** - сервер виконує запити на внутрішні ресурси за контролем атакуючого.

XSS (Cross-Site Scripting)

XSS - впровадження шкідливого JavaScript-коду. Типи: **Stored XSS** (зберігається в БД), **Reflected XSS** (у URL-параметрах), **DOM-based XSS** (маніпуляція DOM). Захист: екранування виводу, використання React (автоматично екранує JSX), заборона `dangerouslySetInnerHTML`, CSP заголовки.

CSRF (Cross-Site Request Forgery)

CSRF - виконання небажаних дій від імені авторизованого користувача. Захист: CSRF-токени, SameSite cookies, перевірка Origin/Referer заголовків.

Content Security Policy (CSP)

CSP - HTTP-заголовок, що обмежує джерела контенту: скриптів, стилів, зображень, шрифтів. Директиви: `default-src`, `script-src`, `style-src`, `img-src`, `connect-src`. Блокує inline-скрипти та завантаження з невідомих доменів.

HTTPS

HTTPS - HTTP з TLS-шифруванням. Захищає дані в транзиті від перехоплення та модифікації. Заголовок `Strict-Transport-Security` (HSTS) змушує браузер використовувати тільки HTTPS.

Контрольні питання

1. Що таке OWASP і чому OWASP Top 10 важливий для веб-розробників?
2. Що таке Broken Access Control і як від нього захиститися?

3. Поясніть різницю між SQL Injection та XSS. Як запобігти кожній з цих атак?
4. Які три типи XSS існують і чим вони відрізняються?
5. Як React захищає від XSS за замовчуванням?
6. Що таке CSRF і які механізми захисту від нього існують?
7. Як працює Content Security Policy (CSP) і які директиви найважливіші?
8. Чому HTTPS необхідний для сучасних веб-застосунків?

Порядок виконання

1. Вивчити теоретичний матеріал, наведений у цьому документі.
2. Ознайомитись з рекомендованими джерелами.
3. Відповісти на контрольні питання.

Рекомендовані джерела

- [OWASP Top 10](#) - офіційний перелік вразливостей
- [OWASP Cheat Sheet Series](#) - практичні рекомендації по безпеці
- [MDN - Content Security Policy](#) - документація CSP
- [MDN - Cross-Site Scripting \(XSS\)](#) - опис XSS
- [Helmet.js](#) - middleware для налаштування HTTP-заголовків безпеки в Node.js
- [PortSwigger Web Security Academy](#) - інтерактивні лабораторні роботи з веб-безпеки